

INFORMATION SECURITY 3 • LECTURE

Incident Response

Identify, analyze, and respond to cybersecurity incidents — effectively.

Mid-State Technical College

Cybersecurity Program



THIS WEEK

Announcements



Discussion



What's new?



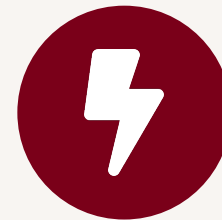
Breaches

Recent compromises and data leaks



News

Industry headlines and advisories



Attacks

Active campaigns and techniques



APT Activity

Nation-state actors and tracked groups

What We'll Cover

01

What is Incident Response?

Definitions, scope, and why it matters

02

The IR Team (CSIRT)

Roles, responsibilities, and cross-functional structure

03

The Incident Response Lifecycle

Six phases from preparation to post-incident review

04

Security Tools & Technologies

SIEM, EDR, forensics, threat intel, SOAR

05

Remediation Strategies

Firewall, content filter, endpoint

06

Hands-On Labs

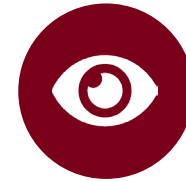
Three labs covering the full lifecycle

What Is Incident Response?

Definition

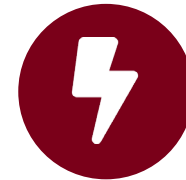
Incident Response (IR) is the organized, documented approach an organization takes to prepare for, detect, contain, and recover from cybersecurity incidents — while minimizing damage and restoring normal operations.

"Incidents are inevitable. How well you respond is what separates a contained event from a catastrophic breach."



Visibility

See what's happening across endpoints, networks, and logs.



Speed

Detect and contain threats before they spread or exfiltrate data.



Improvement

Learn from every incident and harden defenses for the next one.

The Cost of Poor Response



194

days

Average time to identify a breach



64

days

Average time to contain a breach



\$4.88M

Global average total cost of a data breach



70%

Of breached organizations report
significant disruption

Source: IBM Cost of a Data Breach Report 2024 (global averages across 604 organizations in 16 countries).

Strong incident response shrinks these numbers. Preparation is the single biggest lever.

Learning Objectives



Understand the IR lifecycle

Explain each phase and how they interconnect.



Recognize indicators of compromise

Spot failed logins, anomalous traffic, suspicious log entries.



Use security tools effectively

Collect logs, build alerts, and investigate events in a SIEM.



Respond to security events

Isolate systems and review key data points to contain threats.



Document and report findings

Produce detection times, impacted systems, and lessons learned.



Apply continuous improvement

Refine detection rules and procedures after each incident.

Who's on a CSIRT?



IR Manager

Coordinates response, communicates with stakeholders, and drives execution of the IR plan.



Security Analysts

Reconstruct timelines, enrich alerts, and gather the who-what-where details.



Forensic Analysts

Preserve evidence, maintain chain of custody, and perform deep artifact analysis.



Threat Researchers

Track emerging threats and provide context on tactics, techniques, and procedures.



Legal, HR, PR

Handle legal exposure, personnel impacts, and external communications.

IR is not an IT-only function. Effective CSIRTs pull expertise from across the organization.

A CSIRT Is Cross-Functional



Incident response is everyone's job. IT runs the playbook, but legal, HR, and communications decide how the organization survives the fallout.

— Common CSIRT wisdom

Teams You'll Pull From



IT Operations

Systems, networks, access



Security Engineering

Detection engineering, tooling



Legal & Compliance

Regulatory, contractual obligations



Communications

Internal messaging, PR, customer comms



Human Resources

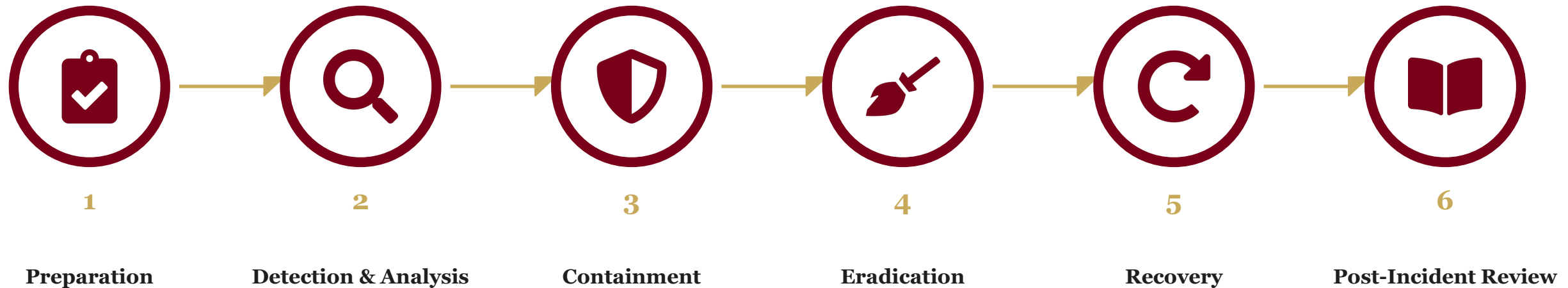
Insider issues, personnel impact



Executive Leadership

Authority, risk acceptance, spend

Six Phases, One Continuous Loop



Lessons from Phase 6 feed directly back into Phase 1 — IR is a continuous improvement loop, not a one-way checklist.

Preparation



Build the foundation before an incident happens. A well-prepared organization has procedures, contacts, and tooling ready before the first alert fires.

Key Activities

- Develop and maintain the incident response plan
- Define roles, responsibilities, and escalation paths
- Deploy logging, monitoring, and response tools
- Establish communication channels (primary and out-of-band)
- Run tabletop exercises and red-team drills

You Should Have

- Written IR plan with version history
- Current on-call roster and contact tree
- Jump-kit: forensic laptop, USB tools, clean media
- Pre-approved containment actions
- Baseline of "normal" for your environment

Detection & Analysis



Monitor continuously, triage aggressively. The goal is to separate real incidents from noise quickly and accurately enough to act.

Key Activities

- Ingest logs from endpoints, network, identity, cloud
- Correlate alerts in a SIEM to surface multi-source patterns
- Validate alerts: true positive, false positive, or benign
- Scope and classify: severity, impacted assets, attack stage
- Open the incident and notify stakeholders per the plan

Watch For

- Repeated failed logins or password-spray patterns
- Unusual outbound traffic to rare destinations
- New admin accounts or unexpected privilege changes
- Disabled security controls, cleared logs
- Processes spawning from Office apps or unusual paths

Containment



Stop the bleeding — without making things worse. Balance attack-prevention against business continuity, and preserve evidence along the way.

Key Activities

- Short-term: isolate affected hosts from the network
- Long-term: deploy filtering, block C2 IPs/domains at the edge
- Revoke compromised credentials; rotate service accounts
- Preserve volatile evidence (memory, live connections)
- Document every action with a timestamp and approver

Containment Tradeoffs

- Isolating fast limits damage but tips off the attacker
- Leaving a system online may enable broader monitoring
- Killing a process destroys evidence you may need later
- Some systems can't be taken offline without business impact
- Pre-approved authority lists remove in-the-moment friction

Eradication



Remove the threat completely — not just the symptoms. Eradication is thorough, systematic, and informed by root-cause analysis.

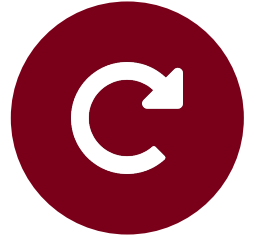
Key Activities

- Identify the root cause and initial access vector
- Remove malware, webshells, unauthorized accounts
- Patch the exploited vulnerability everywhere it lives
- Rebuild systems from trusted images where practical
- Harden configurations before bringing systems back

Confirm Before Moving On

- Every affected host has been assessed and cleaned
- Persistence mechanisms are removed (scheduled tasks, services, cron)
- All compromised credentials are rotated
- Exploited vulnerabilities are patched organization-wide
- Detections exist for the attacker's specific TTPs

Recovery



Safely restore normal operations. Recovery is a phased process with heightened monitoring — not a flip of the switch.

Key Activities

- Restore from verified-clean backups
- Validate system integrity before reconnecting
- Return services in phases, prioritizing critical functions
- Apply heightened monitoring to recently-recovered systems
- Communicate status to users and business stakeholders

Exit Criteria

- No active attacker activity for a defined dwell-time window
- All critical business functions operating normally
- Stakeholders agree the incident is closed operationally
- Monitoring baselines re-established
- Handoff to post-incident review

Post-Incident Review



The incident is over. The learning is just starting. A blameless, honest review is where your organization actually gets better at security.

Key Activities

- Reconstruct the full incident timeline
- Identify what worked, what didn't, and why
- Analyze detection gaps and response friction
- Capture action items with owners and due dates
- Update the IR plan, runbooks, and training

Review Outputs

- Written incident report (executive summary + technical detail)
- Timeline of detections, actions, and decisions
- Root-cause analysis
- Action item list with owners and deadlines
- Updated detections and runbooks

Security Tools & Technologies



SIEM

Central nervous system

Ingest, correlate, and alert on logs from across the environment.



Network Monitoring

Wire-level visibility

Detect C2, exfiltration, and lateral movement on the network.



EDR

Endpoint detection

Deep visibility and response actions at the device level.



Forensics

Preserve & investigate

Collect and analyze evidence without altering it.



Threat Intel

Know the adversary

Context on actors, TTPs, and indicators of compromise.



SOAR

Orchestrate & automate

Standardize response and automate the repetitive work.

SIEM & Network Monitoring



SIEM

Security Information & Event Management

What it does

SIEMs ingest, normalize, correlate, and analyze massive volumes of log data from across the IT environment — transforming raw events into actionable intelligence through correlation rules, dashboards, and alerting.

Examples

Splunk Enterprise Security · IBM QRadar · Elastic Stack with Security · LogRhythm · Microsoft Sentinel · Wazuh



Network Monitoring

Wire-level detection & analysis

What it does

Packet capture, NetFlow, and network detection tools provide visibility into communications across the enterprise. Useful for detecting C2, exfiltration, and lateral movement — especially on IoT and legacy systems without endpoint agents.

Examples

Wireshark · Zeek (Bro) · Suricata · Darktrace · Cisco Stealthwatch · ExtraHop Reveal(x)

EDR & Forensics



EDR

Endpoint Detection & Response

What it does

Modern EDR uses behavioral analysis, machine learning, and threat intelligence to detect attacks that bypass signature-based tools — including fileless malware and living-off-the-land techniques — with response actions like process kill, quarantine, and host isolation.

Examples

CrowdStrike Falcon · Microsoft Defender for Endpoint · SentinelOne · VMware Carbon Black · Sophos Intercept X



Forensics

Collect, preserve, analyze evidence

What it does

Forensic tools collect and analyze evidence from compromised systems without altering the original data. They recover deleted files, extract memory artifacts, parse logs, and rebuild timelines — supporting both technical analysis and legal proceedings.

Examples

EnCase Forensic · FTK · Autopsy · Volatility Framework · SANS SIFT Workstation · Magnet AXIOM

Threat Intelligence & SOAR



Threat Intel Platforms

Context on adversaries and TTPs

What it does

TIPs aggregate data from commercial feeds, open source, industry sharing groups, and internal observations to help you understand the tactics, techniques, and procedures of relevant threat actors — and prioritize accordingly.

Examples

ThreatConnect · Recorded Future · Anomali ThreatStream · MISP · AlienVault OTX



SOAR

Security Orchestration, Automation, Response

What it does

SOAR platforms connect disparate security tools, automate repetitive tasks, and guide analysts through standardized playbooks — reducing alert fatigue and freeing expertise for complex decisions that need human judgment.

Examples

Palo Alto Cortex XSOAR · Splunk SOAR (Phantom) · IBM Security SOAR · Google Chronicle SOAR

Remediation Strategies



Firewall

- Analyze the attack vector
- Reduce attack surface via config changes
- Implement new security controls
- Update existing control configurations
- Configure egress filtering
- Detect and block covert channels



Content Filter

- Configure secure web gateway egress filtering
- Update URL and content filtering with threat data
- Review DLP mechanisms
- Verify MDM coverage
- Update or revoke compromised certificates
- Remove compromised root certs from trust stores



Endpoint

- Re-assess attack surface and vectors
- Evaluate social engineering exposure
- Patch technical vulnerabilities
- Implement stronger controls
- Resolve configuration drift
- Apply least privilege principles

SIEM Correlation & Triage



Objective

Identify and correlate suspicious events across multiple log sources. Simulate a targeted attack to trigger alerts, then triage and prioritize them.



Setup

Splunk or Wazuh receiving logs from a Windows and a Linux system. Kali Linux is used to generate the simulated attack traffic.



Expected Outcomes

You'll configure correlation rules, run a Hydra password-spray and privilege-escalation sequence, and investigate the resulting alerts to build an initial incident timeline.

Tools Used

- Splunk / Wazuh
- Kali Linux
- Hydra
- OpenSSH
- Windows & Linux targets

Questions?

Take a moment. Incident response is more judgment than procedure — the best way to learn it is by working through real scenarios together.

Assignments for next week:

- *Lab 1: SIEM Correlation & Triage with Splunk or Wazuh*
- *Incident Response Case Study*
- *Unit 12 Quiz*

Recommended Resources

Frameworks & Standards

- NIST Cybersecurity Framework
- MITRE ATT&CK Framework
- SANS Reading Room
- Awesome Incident Response (GitHub)

Playbooks & Guides

- CISA Federal IR & Vulnerability Playbooks
- BOMA Canada Cyber IR Guide